

Web and API Pentesting Checklist

1 Pre-Engagement & Scope

- Confirm written authorization
- Identify in-scope domains/IPs
- Identify web applications
- Identify API endpoints
- Identify API versions
- Identify test accounts and roles
- Identify production/staging environments
- Confirm testing restrictions
- Confirm rate/traffic limits
- Establish reporting requirements

OWASP:

[OWASP WSTG – Introduction & Objectives](#)

2 Reconnaissance & Attack Surface Discovery

Web

- Subdomain discovery
- Application discovery
- Technology fingerprinting
- Web server identification
- Framework identification
- Directory/file discovery
- Identify administrative interfaces
- Identify backup files
- Review `robots.txt`
- Review `sitemap.xml`
- Identify exposed documentation
- Identify JavaScript endpoints

API

- Discover REST APIs
- Discover GraphQL
- Discover SOAP
- Discover WebSockets
- Discover gRPC where applicable
- Find Swagger/OpenAPI documentation
- Identify undocumented endpoints
- Identify deprecated endpoints
- Identify development/staging APIs

OWASP:

[WSTG – Information Gathering](#)

[API9:2023 – Improper Inventory Management](#)

3 Configuration & Deployment

- HTTP → HTTPS redirect
- TLS configuration
- Security headers
- HSTS
- CSP
- X-Content-Type-Options
- X-Frame-Options / CSP `frame-ancestors`
- Referrer-Policy
- CORS
- Unnecessary HTTP methods
- Directory listing
- Debug mode
- Default files
- Default credentials
- Backup files
- Verbose errors
- Server information disclosure

OWASP:

[WSTG – Configuration & Deployment Management](#)

[API8:2023 – Security Misconfiguration](#)

4 Identity & User Enumeration

Username enumeration

Email enumeration

Account discovery

User registration

Account modification

Account deletion

Duplicate account handling

Role assignment

Default roles

Administrative accounts

OWASP:

[WSTG – Identity Management Testing](#)

5 Authentication

Web & API

Login functionality

Authentication bypass

Weak password policy

Default credentials

Brute-force protection

Rate limiting

Account lockout

CAPTCHA controls

MFA implementation

Password reset

Password change

Email/phone verification

Alternative authentication mechanisms

API-specific

- Missing authentication
- Invalid token handling
- Expired token handling
- Token reuse
- Token revocation
- OAuth implementation
- JWT validation

OWASP:

[WSTG – Authentication Testing](#)

[API2:2023 – Broken Authentication](#)

6 Authorization & Access Control

Horizontal Authorization

- User A $\rightarrow$ User B data
- Change object IDs
- IDOR
- BOLA
- Cross-tenant access
- Resource ownership validation

Vertical Authorization

- Normal user $\rightarrow$ admin functionality
- Privileged endpoint access
- HTTP method manipulation
- Hidden administrative functionality
- Role manipulation
- Function-level authorization

API

BOLA

Broken function-level authorization

Property-level authorization

Tenant isolation

Object ownership

OWASP:

[WSTG – Authorization Testing](#)

[API1:2023 – Broken Object Level Authorization](#)

[API3:2023 – Broken Object Property Level Authorization](#)

[API5:2023 – Broken Function Level Authorization](#)

7 Session Management

Session ID randomness

Session fixation

Session hijacking

Session timeout

Logout invalidation

Concurrent sessions

Password-change session invalidation

Cookie **Secure**

Cookie **HttpOnly**

Cookie **SameSite**

Session token exposure

Session token in URL

API

Bearer token handling

Refresh tokens

Token expiration

Token revocation

Token reuse

OWASP:

[WSTG – Session Management Testing](#)

8 Input Validation & Injection

Test:

Query parameters

POST parameters

JSON

XML

Headers

Cookies

Path parameters

File names

HTTP methods

Injection Classes

SQL Injection

NoSQL Injection

LDAP Injection

XML Injection

XPath Injection

Command Injection

Template Injection

Expression Language Injection

HTTP Parameter Pollution

Host Header Injection

CRLF Injection

CSV Injection

Prototype Pollution

OWASP:

[WSTG – Input Validation Testing](#)

9 Cross-Site Scripting

Reflected XSS

Stored XSS

DOM XSS

HTML context

Attribute context

JavaScript context

URL context

Encoding validation

CSP effectiveness

API

XSS through API responses

Stored API content rendered by web clients

Unsafe HTML fields

Unsafe JSON-to-HTML rendering

OWASP:

[WSTG – Testing for Reflected Cross-Site Scripting](#)

[WSTG – Testing for Stored Cross-Site Scripting](#)

[WSTG – Testing for DOM-Based Cross-Site Scripting](#)

10 File Upload & File Handling

Extension validation

MIME validation

Content validation

Filename sanitization

Path traversal

Double extensions

Executable file handling

SVG handling

HTML file handling

File size limits

File permissions

File download authorization

Image/document processing

OWASP:

[WSTG – Testing for File Inclusion](#)

11 Path Traversal

Directory traversal

Local file inclusion

Remote file inclusion

Encoded traversal

File download manipulation

Path parameter manipulation

OWASP:

[WSTG – File Inclusion Testing](#)

12 SSRF

Identify server-side URL fetching:

URL preview

Webhooks

Remote image import

PDF generation

Remote file import

Integrations

Callback URLs

Test protections:

Internal network access controls

URL allowlists

Redirect handling

DNS rebinding protections

Cloud metadata protection

OWASP:

[WSTG – Server-Side Request Forgery](#)

[API7:2023 – Server Side Request Forgery](#)

13 CSRF

CSRF token present

Token validated

Token tied appropriately to session

SameSite cookie controls

Origin validation

Referer validation

Unsafe GET requests

Test state-changing operations:

Password change

Email change

Account settings

Transactions

Administrative actions

OWASP:

[WSTG – Testing for Cross-Site Request Forgery](#)

14 CORS

Allowed origins

Arbitrary origin handling

null origin

Credentialed requests

Wildcard origins

Sensitive API endpoints

Preflight behavior

OWASP:

[WSTG – Testing Cross Origin Resource Sharing](#)

15 Business Logic

Web + API

- Workflow bypass
- Step skipping
- Price manipulation
- Quantity manipulation
- Coupon abuse
- Transaction replay
- Duplicate transactions
- Race conditions
- Verification bypass
- Account recovery abuse
- Approval bypass
- Limits bypass

API

- Sensitive business flows
- Automated abuse
- Transaction manipulation
- Excessive operations
- Workflow state manipulation

OWASP:

[WSTG – Business Logic Testing](#)

[API6:2023 – Unrestricted Access to Sensitive Business Flows](#)

16 API-Specific Testing

API Discovery

- Swagger/OpenAPI
- API documentation
- Hidden endpoints
- Deprecated endpoints
- Old API versions
- Shadow APIs

[API9:2023 – Improper Inventory Management](#)

API Authentication

API keys

Bearer tokens

JWT

OAuth

Session authentication

Token expiration

Token revocation

[API2:2023 – Broken Authentication](#)

API Authorization

BOLA

BFLA

Property-level authorization

Tenant isolation

Object ownership

[API1:2023 – BOLA](#)

[API3:2023 – Object Property Level Authorization](#)

[API5:2023 – BFLA](#)

17 Mass Assignment / Property-Level Authorization

Test server-controlled properties such as:

`role`

`isAdmin`

`permissions`

`ownerId`

`userId`

`status`

`price`

`balance`

Verify that unauthorized properties cannot be changed.

OWASP:

[API3:2023 – Broken Object Property Level Authorization](#)

18 API Rate Limiting / Resource Consumption

Test:

- Login
- OTP
- Password reset
- Account recovery
- Token generation
- Expensive search
- File upload
- Transaction APIs
- Large request bodies

Check:

- Per-IP limits
- Per-user limits
- Per-token limits
- Rate-limit headers
- Appropriate throttling

Stay within authorized traffic limits.

OWASP:

[API4:2023 – Unrestricted Resource Consumption](#)

19 JWT

- Signature validation
- Algorithm validation
- Expiration validation
- Issuer validation
- Audience validation
- Token lifetime
- Key management
- Privilege claims
- Refresh-token handling
- Token revocation

OWASP:

[WSTG – Testing JSON Web Tokens](#)

[API2:2023 – Broken Authentication](#)

20 GraphQL

If GraphQL is used:

- Introspection
- Query depth
- Query complexity
- Resolver authorization
- Sensitive fields
- Mutation authorization
- Batch queries
- Aliasing
- Error disclosure

OWASP:

[WSTG – API Testing](#)

21 WebSockets

- Authentication
- Authorization
- Origin validation
- Message manipulation
- Cross-user access
- Sensitive data exposure
- Connection limits
- Session termination

OWASP:

[WSTG – Client-Side Testing](#)

22 Error Handling & Information Disclosure

- Stack traces
- Framework versions
- Database errors
- Internal paths
- Debug information

- Configuration disclosure
- API implementation details
- Internal IP addresses
- Sensitive response fields

OWASP:

[WSTG – Error Handling Testing](#)

23 Sensitive Data Exposure

- Passwords
- Password hashes
- API keys
- Tokens
- PII
- Internal IDs
- Internal IPs
- Database information
- Debug information
- Secrets in JavaScript
- Secrets in source maps
- Sensitive data in URLs
- Sensitive data in cached responses

OWASP:

[WSTG – Information Gathering / Information Disclosure](#)

[API3:2023 – Broken Object Property Level Authorization](#)

24 API Versioning & Inventory

- /v1
- /v2
- /v3
- Legacy endpoints
- Deprecated APIs
- Shadow APIs
- Staging APIs

Development APIs

Undocumented APIs

Compare old/new versions for:

Authentication

Authorization

Data exposure

Security controls

Deprecated functionality

OWASP:

[API9:2023 – Improper Inventory Management](#)

25 Third-Party API Consumption

Third-party API authentication

TLS validation

Response validation

Input validation

Redirect handling

Trust boundaries

Error handling

Sensitive data shared with third parties

OWASP:

[API10:2023 – Unsafe Consumption of APIs](#)

26 Cryptography

TLS

Weak protocols

Weak cipher suites

Password hashing

Weak cryptographic algorithms

Hardcoded encryption keys

Insecure random numbers

Improper key management

Sensitive data encryption

OWASP:

[WSTG – Testing for Weak Cryptography](#)

27 Client-Side Security

JavaScript review

DOM XSS

Sensitive information in JavaScript

Source maps

Browser storage

LocalStorage

SessionStorage

Web messaging

CORS

Clickjacking

Client-side URL manipulation

OWASP:

[WSTG – Client-Side Testing](#)

28 HTTP-Level Testing

HTTP method manipulation

Request smuggling

HTTP parameter pollution

Host header injection

Cache poisoning

Cache deception

CRLF injection

Proxy/header trust issues

OWASP:

[WSTG – Input Validation Testing](#)

[WSTG – Configuration & Deployment Management](#)

29 Automated Testing

Use automation as an aid and manually validate findings.

Burp Suite

Nmap

Nuclei

API schema testing

TLS testing

Dependency scanning

SAST results

Passive scanning

Content discovery

OWASP:
[OWASP WSTG – Latest](#)

30 Evidence & Reporting

For every confirmed finding:

Finding title

OWASP category

Affected URL

HTTP method

Parameter

Authentication state

User role

Request

Response

Reproduction steps

Impact

Severity

CVSS

Screenshot

Remediation

Retest result